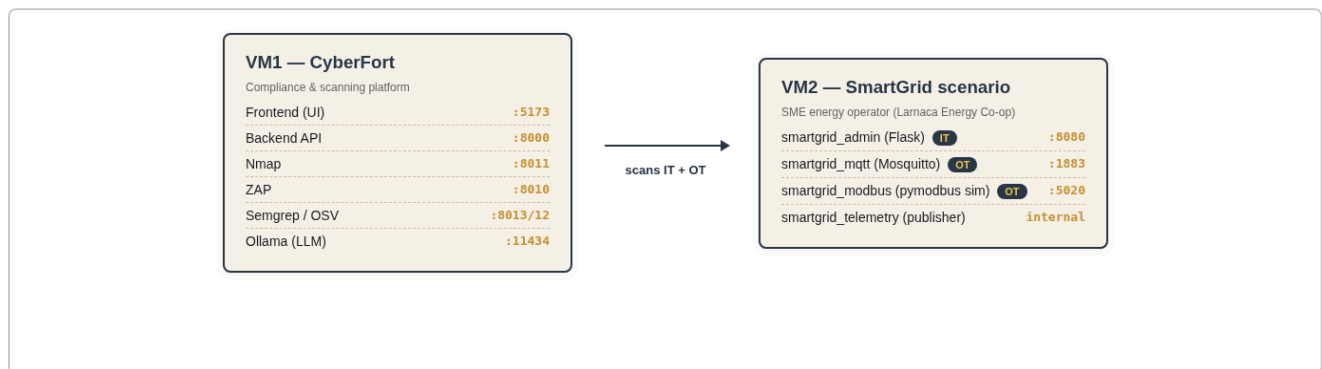


Scenario 02 — SmartGrid Meter (Energy)

Instructor guide & answer key

This document is **not** for trainees. It contains the seeded vulnerabilities, expected CyberFort findings, **what a successful deliverable looks like**, scoring rubric, and remediation patches.

1. Scenario topology



All three exposed ports are reachable from any host on the cyber-range subnet. Internal-only is `smartgrid_telemetry` (the publisher).

2. Seeded vulnerabilities (the answer key)

#	Vulnerability	Where	Detected by	NIS2 Article 21(2) measure
1	MQTT broker accepts anonymous subscribers + publishers	<code>mosquitto/mosquitto.conf</code> (<code>allow_anonymous true</code>)	Nmap + manual <code>mosquitto_sub</code>	(d), (e), (h)
2	Modbus TCP simulator reachable with no segmentation	<code>modbus/simulator.py</code> + <code>docker-compose.yml</code>	Nmap + pymodbus client	(b), (e)
3	Default operator credentials <code>admin/admin</code>	<code>admin/meter_admin/app.py</code> <code>USERS</code> dict	ZAP auth-attack rule	(i)
4	Firmware upload accepts arbitrary file types	<code>admin/meter_admin/app.py</code> <code>firmware()</code> route	ZAP + Semgrep <code>arbitrary-file-write</code>	(d), (e)
5	Hardcoded MQTT credentials in publisher source	<code>telemetry/publisher.py</code> line 22	Semgrep <code>hardcoded-password</code>	(j)

#	Vulnerability	Where	Detected by	NIS2 Article 21(2) measure
6	Hardcoded billing-API key in admin config	admin/meter_admin/config.py	Semgrep	(j)
7	Flask debug=True shipped to production	admin/meter_admin/app.py bottom + run.py	Semgrep flask-debug-true	(e)
8	Outdated dependencies — Flask 2.0.1, Werkzeug 2.0.1, pymodbus 2.5.3, paho-mqtt 1.5.1, requests 2.25.0	admin/requirements.txt	OSV	(d)

3. Demonstration credentials

System	Username	Password
SmartGrid web UI	admin	admin
SmartGrid web UI (alt)	field_eng	fieldeng
MQTT broker (hardcoded)	ops	OpsTopSecret#2024
MQTT broker (effective)	(anonymous)	(any password works)

4. Verification commands — with expected output

Run these against a live SmartGrid stack to confirm each finding before grading the trainee.

4.1 Anonymous MQTT subscribe

```
mosquitto_sub -h <VM2> -p 1883 -t 'smartgrid/#' -v -W 8
```

Expected output (key lines):

```
smartgrid/meter-larnaca-001/telemetry {"meter_id": "meter-larnaca-001", "power_w": 5299, "voltage_v":
smartgrid/meter-paphos-014/telemetry {"meter_id": "meter-paphos-014", ...}
smartgrid/meter-nicosia-027/telemetry {"meter_id": "meter-nicosia-027", ...}
-- total messages in 8s: 6 --
```

4.2 Modbus TCP — unauthenticated read

```
docker exec smartgrid_admin python -c "  
from pymodbus.client.sync import ModbusTcpClient  
c = ModbusTcpClient('modbus', port=5020); c.connect()  
print(c.read_holding_registers(0, 9, unit=1).registers)  
"
```

Expected output:

```
[4121, 2282, 2301, 1116, 1048, 1350, 2, 6346, 324]
```

4.3 Default web credentials

```
curl -i -X POST http://<VM2>:8080/login -d "username=admin" -d "password=admin" | head -8
```

Expected output:

```
HTTP/1.0 302 FOUND  
Location: http://<VM2>:8080/dashboard  
Set-Cookie: session=...; HttpOnly; Path=/  
Server: Werkzeug/2.0.1 Python/3.9.x
```

4.4 Firmware upload accepts an arbitrary file

```
echo 'print("rce")' > /tmp/rogue.py  
curl -s -b cookies.txt -F file=@/tmp/rogue.py http://<VM2>:8080/firmware | grep -oE 'Uploaded [^<]+'
```

Expected output:

```
Uploaded <code>rogue.py
```

5. What each exploit looks like

5.1 SmartGrid sign-in page (clean baseline)

 Meter Operations Console

Sign in

Operator credentials are issued by the grid operations manager.

Username

Password

Sign in

SmartGrid Meter Admin v1.3.0 · Lamaca Energy Co-op · build f8e2-r3

5.2 Default credentials in the login form

 Meter Operations Console

Sign in

Operator credentials are issued by the grid operations manager.

Username

Password

Sign in

SmartGrid Meter Admin v1.3.0 · Lamaca Energy Co-op · build f8e2-r3

5.3 Fleet telemetry dashboard (signed in)

SmartGrid

Meter Operations Console

DashboardFirmwareadminLogout

Fleet telemetry

Latest MQTT samples from each meter. Click a meter to read its Modbus registers.

Meter	Power (W)	Voltage (V)	Total kWh	Tariff	Registers
meter-larnaca-001	2861	229.52	138393.0	day	Read Modbus #1
meter-paphos-014	3685	229.08	127087.1	night	Read Modbus #2
meter-nicosia-027	3031	230.47	128351.9	night	Read Modbus #3

SmartGrid Meter Admin v1.3.0 · Larnaca Energy Co-op · build f8e2-r3

5.4 Modbus holding registers, live-read over the management UI

SmartGrid

Meter Operations Console

DashboardFirmwareadminLogout

Meter #1 — Modbus holding registers

Live read from the meter over Modbus TCP.

#	Description	Raw value
---	-------------	-----------

[« Back to dashboard](#)

SmartGrid Meter Admin v1.3.0 · Larnaca Energy Co-op · build f8e2-r3

5.5 Firmware upload accepting an arbitrary `.py` file

SmartGrid Meter Operations Console

DashboardFirmwareadminLogout

Firmware upload

Upload a new firmware image (.bin) to stage it for the next fleet update window.

Uploaded `rogue.py`

Choose FileNo file chosen

Upload

Staged firmware images

- `_rogue.py`
- `rogue.py`

SmartGrid Meter Admin v1.3.0 · Larnaca Energy Co-op · build f8e2-r3

6. What a successful deliverable looks like in CyberFort

6.1 The risk register populated with SmartGrid findings

The Risk Registry tab should contain at least eight new risks scoped to `SmartGrid Meter Admin 1.3.0`.

- [Dashboard](#)
- [Assessments](#)
- [Frameworks](#)
- [Assets / Products](#)
- [Risks](#)
 - [Risk Register](#)
 - [Risk Assessment](#)
 - [Incident Registration](#)
 - [Security Advisories](#)
- [Controls](#)
- [Documents](#)
- [Compliance Chain](#)
- [Audit Engagements](#)
- [Administration](#)
- [Documentation](#)
- [AI Assistant](#)

manastasiadis
CRA Extended

Risk Management

[Dashboard](#)
[Risk Registry 89](#)
[Risk Templates Library 110](#)
[Connections](#)

+ Add New Risk
Export to PDF (89)

Code	Risk Category	Description	Status (Treatment)	Severity	Assessment	Likelihood
RSK-1	DNS Attacks	Attacks targeting Domain Name ...	Accept	Medium	Not Assessed	Medium
RSK-13	Phishing Attacks	Social engineering attacks that tr...	Accept	Medium	Assessment in progress	Low
RSK-30	Accidental fire, water,...	Risk of outages and loss due to ...	Accept	Medium	-	Medium
RSK-31	Availability & Disaste...	Risk of system outage due to a d...	Accept	Medium	-	Medium
RSK-32	Broken or weak auth...	Risk of account hijacking or expl...	Accept	Medium	-	Medium
RSK-33	Brute force attack	Risk of malicious user getting ac...	Accept	Medium	-	Medium
RSK-34	Cancelled contract	A contract is cancelled due to a ...	Accept	Medium	-	Medium
RSK-35	Cloud misconfiguration	Lack of baseline configuration wi...	Accept	Medium	-	Medium
RSK-36	DNS Spoofing	Risk of data theft and malware di...	Accept	Medium	-	Medium
RSK-37	Data breach	Open ports, unrestricted protocol...	Accept	Medium	-	Medium

1-10 of 89 risks
 <
1
2
3
4
5
...
9
>
10 / page

6.2 The NIS2 conformity assessment, answered

The **SmartGrid NIS2 Conformity** assessment should show progress on the ten target questions in Step 7 of the handbook.

Assessment Overview

View your active assessments or create new ones

Active Assessments 3

Assessments currently in progress

- SmartGrid NIS2 Conformity

CRA • Product: SmartGrid Meter Admin

0%

Selected
- PortPilot CRA Conformity

CRA • Product: PortPilot

0%
- pentest

Create New Assessment

Start a new assessment for a framework

Framework
CRA

Assessment Type
Conformity

Scope Type *
Select scope type

Assessment Name
Enter assessment name

CreateCancel

3
Total0
Completed

Select Assessment

Or browse and select from existing assessments

Framework
CRA

Assessment Type
Conformity

Assessment
SmartGrid NIS2 Conformity

Delete Assessment

Assessment Questions (Asset / Product: SmartGrid Meter Admin)

Question 1

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?

☐ Yes ☒ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 2

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Do you take the outcome of the cybersecurity risk assessment into account during the planning, design, development, production, delivery and maintenance phases?

☐ Yes ☒ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 3

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Is your cybersecurity risk assessment documented and updated as appropriate during the support period?

Save Answer

Clear Answer

Attach File(s)

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 4

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your cybersecurity risk assessment comprise an analysis based on the intended purpose and reasonably foreseeable use of the product?

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 5

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your risk assessment take into account the conditions of use, operational environment, and assets to be protected?

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 6

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your risk assessment consider the length of time the product is expected to be in use?

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 7

Mandatory: YES Completed: NO Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your cybersecurity risk assessment indicate whether and how the security requirements are applicable to your product?

Yes

No

Partially

N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 8

Mandatory: YES Completed: NO Common in: CRA (clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Do you include the cybersecurity risk assessment in the technical documentation when placing the product on the market?

Yes

No

Partially

N/A

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

Question 9
Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Where certain essential cybersecurity requirements are not applicable, do you include clear justification in the technical documentation?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer
Clear Answer
Attach File(s)

Question 10
Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer
Clear Answer
Attach File(s)

1-10 of 52 questions
1 2 3 4 5 6 >

7. Risk-register expected entries (detailed)

After the trainee finishes the scenario the register should contain **at least 7 risks** linked to **SmartGrid Meter Admin 1.3.0** :

1. MQTT anonymous access — H/H
2. MQTT clear-text telemetry — H/M
3. Modbus TCP exposed without segmentation — H/VH
4. Default operator credentials — H/H
5. Arbitrary firmware upload — M/H
6. Hardcoded credentials in source — M/H
7. Outdated dependencies (OSV) — H/M

8. Scoring rubric (100 pts)

Activity	Points
Product registered	5
Nmap scan and conversion of three port findings (MQTT, Modbus, HTTP)	15
MQTT anonymous-subscribe verification	10
Modbus unauth-read verification	10
ZAP scan + default-creds + file-upload findings	15
Semgrep + hardcoded-secret finding	10
OSV + at least one dep advisory filed	10
NIS2 assessment with all 10 Step-7 questions answered	20
Report PDF generated	5

Pass threshold: 70.

9. Remediation patches

- **MQTT:** in `mosquitto/mosquitto.conf` set `allow_anonymous false`, add a TLS `listener 8883 0.0.0.0` block, configure `password_file`.
- **Modbus:** remove the `ports: 5020:5020` mapping in `docker-compose.yml` so the protocol stays on the internal docker network. Long-term: use a Modbus-aware gateway with allow-listing.
- **Default creds:** delete the seeded `admin/admin` from the in-memory `USERS` dict; force a password change on first login.
- **Firmware upload:** allow-list `.bin` only, verify a vendor signature before staging, write the file outside the web root.
- **Hardcoded secrets:** move `BILLING_API_KEY`, `MQTT_PASSWORD`, `SECRET_KEY` into env vars.
- **Debug mode:** set `debug=False`; use `gunicorn` for production.
- **Dependencies:** bump Flask to 3.0.3, Werkzeug to 3.0.3, paho-mqtt to 1.6.1, pymodbus to 3.6.6, requests to 2.32.3.

10. Reset between sessions

```
cd /srv/smartgrid-scenario  
docker compose down  
docker compose up -d --build
```

(No persistent volumes — every restart is factory fresh.)